

Hey there! You are using **WhatsApp** : Enumerating Three **Billion Accounts for Security and Privacy**

2026.05.29

이시현 | 명지대학교 정보통신공학전공

논문 리뷰

목차

01	introduction
02	왜 WhatsApp인가? 이 논문을 고른 이유
04	Attack Methodology 공격 방법
05	Limitations & Future Work
06	느낀 점
07	References

01. introduction & 왜 whatsapp 인가?

introduction

연구 배경

왓츠앱의 연락처 확인 기능이 대규모 전화번호 열거 공격에 취약함을 인지하고, 과거 유출 데이터의 유효성과 현재 방어 체계의 실효성을 재평가하고자 연구를 시작했다.

기존 방식 및 방어의 한계

- 기존 한계 : 공식 앱 UI 자동화 방식이 느린 속도(34일간 5천만개) 로 전수 조사 불가능
- 방어 무력화 : 내부 API(XMPP) 직접 접근으로 속도 제한 무력화, 단일 서버로 시간당 1억 개 조회
- 과다 노출 : 프로필 사진, 상태 메시지, 암호화 키 등 메타데이터 유출로 기기 OS(안드로이드/IOS) 까지 역추적 가능

제안하는 해결방법

- PSI, Private Set Intersection 기술 도입 : 서버에 데이터를 날것을 보내지 않고 PSI 기술을 도입
- Rate Limiting 재설계 : 비정상적인 대용량 일괄 조회(Batch Query) 패턴을 감지하고 서버 레벨에서 차단
- 프로필 정보의 암호화 보호 : 프로필 등을 메타데이터로 암호화, 신뢰관계가 형성된 지인에게만 이를 복호화 할 수 있는 키 제공
- 클라이언트 코드 통합 : ios와 api 양 플랫폼의 요청 패턴 통합

왜 WhatsApp인가?

기존에 알려진 방어법과 그 한계

- Rate Limiting (속도 제한) : 짧은 시간 안에 너무 많은 조회를 보내면 차단. 하지만 이 논문에서 시간당 1억 개 조회가 차단 없이 성공 — 사실상 무력화
- 2019년 이전 연구들 : Phone number enumeration이 가능하다는 건 알려졌지만, 대규모 실증은 없었음. 위협이 과소 평가되어 있다. [3], [4]
- 플랫폼 정책 (WhatsApp 이용약관) : 자동화된 대량 조회를 금지하고 있음. 하지만 기술적 차단이 아닌 정책에만 의존 — 실질적 억제 효과 없다. [6] (2019 leak), [7] (Yahoo 2013 breach 비교용)

결론

- 기존 방어는 대규모 자동화 공격을 실제로 막지 못함
- 서비스 구조 자체가 열거를 허용할 수밖에 없는 설계

이 논문을 고른 이유

- NDSS 2026 탑 컨퍼런스 논문
- 배경지식 없어도 이해 가능한 주제
- WhatsApp이라는 일상적인 앱의 보안 문제라 흥미로웠음
- 암호화가 완전한 보호가 아니라는 점이 인상적이었음

02. Attack Methodology

Attack Methodology 1 : Initial Exploration

- 처음엔 2021년 Facebook 유출 데이터의 미국 번호만 소규모로 테스트
 - WhatsApp 공식 앱 UI 대신 XMPP API를 직접 호출하는 방식 사용
 - 예상과 달리 차단·속도 제한 전혀 없었음
 - 계정 5개, 서버 1대만으로 1시간 안에 완료
-
- 결론: 소규모 테스트만으로도 Rate Limiting이 사실상 없다는 걸 확인

Attack Methodology 2 : Phone Number Generation

- 전 세계 전화번호를 무작정 다 조회하기엔 너무 많음
 - 그래서 libphonenumber 이라는 자체 도구를 개발해 후보 번호 생성
 - Google의 libphonenumber 라이브러리 기반으로 245개국, 약 630억 개 후보 번호로 압축
-
- 결론: 무작위 대입이 아닌, 실제 사용 가능한 번호만 추려서 효율적으로 공격

Attack Methodology 1 : Initial Exploration

프로토콜	API 엔드포인트	반환되는 정보	속도(초당 조회 계정 수)
XMPP	<u>IsOnWhatsapp</u>	해당 번호가 왓츠앱에 가입되어 있는지 여부 (true / false)	7,000개 / 초
XMPP	<u>GetDeviceList</u>	주 기기 및 연결된 부기기(태블릿, 웹 등)의 인덱스 목록	7,000개 / 초
XMPP	<u>GetUserInfo</u>	프로필 사진 URL 및 타임스탬프, 상태 메시지 내용 및 타임스탬프, 비즈니스 계정 이름	3,000개 / 초
XMPP	<u>GetPrekeys</u>	종단간 암호화(E2EE)에 사용되는 신원 키, 서명된 사전 키, 일회용 사전 키, 타임스탬프	2,000개 / 초
HTTP	<u>FetchPicture</u>	고화질 프로필 사진 실제 다운로드	5,500개 / 초

연구진이 왓츠앱의 각 API 엔드포인트(서버 접속 지점)를 찔러봤을 때, 어떤 정보를 얻을 수 있었고 그 속도가 얼마나 빨랐는지를 보준다.

Attack Methodology 3 : Measurement with Global Coverage

- 630억 개 번호를 WhatsApp에 실제로 조회
 - 초당 7,000개, 시간당 1억 개 이상 조회 가능
 - 2024년 12월 ~ 2025년 4월까지 약 5개월간 측정
 - 끝까지 차단 없음 → 35억 개 활성 계정 확인
-
- 결론: 대학 서버 1대로 전 세계 WhatsApp 사용자 전수 조사 성공

Attack Methodology 3 : Measurement with Global Coverage

국가 코드	국가명	초기 후보 번호 수(# Candidates)	후처리 후 후보 번호 수 (# Candidates (pp))
+43	오스트리아 (AT)	5,111억 개 ●	4억 8,000만 개 □ (대폭 축소)
+62	인도네시아 (ID)	888억 개	44억 4,000만 개 (대폭 축소)
+55	브라질 (BR)	73억 7,000만 개	147억 4,000만 개 (구형 번호 추가로 증가)
+86	중국 (CN)	52억 1,000만 개	52억 1,000만 개
+52	멕시코 (MX)	44억 8,000만 개	89억 6,000만 개 (구형 번호 추가로 증가)
+91	인도 (IN)	33억 3,000만 개	33억 3,000만 개
+1	미국 (US)	28억 7,000만 개	28억 7,000만 개
+49	독일 (DE)	13억 3,000만 개	13억 3,000만 개
+880	방글라데시 (BD)	11억 7,000만 개	11억 7,000만 개
+358	핀란드 (FI)	11억 1,000만 개	11억 1,000만 개
+39	이탈리아 (IT)	10억 8,000만 개	10억 8,000만 개
+7	러시아 (RU)	10억 1,000만 개	10억 1,000만 개
-	그 외 나머지 국가들	175억 2,000만 개	175억 2,000만 개
TOTAL	전 세계 총합	6,463억 9,000만 개	631억 7,000만 개

연구진이 자체 개발한 번호 생성 프로그램(libphonegen)을 돌렸을 때, 국가별로 조사가 필요한 후보 전화번호가 몇 개나 나왔는지, 그리고 데이터 최적화(후처리)를 통해 그 개수를 얼마나 줄였는지를 보여준다.

03. Limitations & Future Work

04. Limitations & Future Work

한계점 (Limitations)

- 데이터 수집 시점 문제 : 2024년 12월 ~ 2025년 4월 사이 측정이라 이후 변동사항 반영 안 됨
- 일부 국가 번호 누락 가능성: 브라질, 멕시코처럼 번호 형식이 바뀐 나라는 구형 번호를 추가로 처리해야 했음 → 다른 나라도 비슷한 문제 있을 수 있음
- WhatsApp만 대상: Telegram, Signal 등 다른 메신저는 동일한 취약점이 있는지 확인 안 됨
- 윤리적 제약: 개인 식별 분석을 의도적으로 하지 않아서 실제 악용 피해 규모는 측정 못 함

향후 과제 (Future Work)

- 플랫폼 측: Rate Limiting 강화, 이상 조회 탐지 시스템 도입 필요
- 연구 측: Telegram, Signal 등 다른 메신저에도 동일 방법론 적용해서 비교 분석
- 제도적 측: 개인정보보호법(GDPR 등) 관점에서 플랫폼의 책임 범위 논의 필요
- 사용자 측: 프로필 공개 범위 설정 강화 옵션 제공 필요

04. 느낀점

05. 느낀점

- "암호화 = 안전"이라는 통념이 깨졌다.
- 서비스 설계 단계부터 프라이버시 고려 필요하는 것을 알게 되었다.
- 보안 연구는 실제 서비스를 대상으로 실증해야 설득력 있다는 것을 배웠다.
- 평범한 기능이 대규모로 악용될 수 있다는 것을 깨달았다.

05. References

04. References

[1] WhatsApp, "About WhatsApp," Accessed Apr 15, 2025. [Online]. Available:

<https://www.whatsapp.com/about/>

[3] S. Schrittwieser, P. Frühwirt, P. Kieseberg, M. Leithner, M. Mulazzani, M. Huber, and E. Weipp, "Guess who is texting you? Evaluating the security of smartphone messaging applications," in NDSS 2012. The Internet Society, 2012.

[4] C. Hagen, C. Weinert, C. Sendner, A. Dmitrienko, and T. Schneider, "All the numbers are US: Large-scale abuse of contact discovery in mobile messenger," in NDSS 2021. The Internet Society, 2021.

[6] M. Clark, "Facts on News Reports About Facebook Data," Meta, Product Management Director, 2021.

[Online]. Available: <https://about.fb.com/news/2021/04/facts-on-news-reports-about-facebook-data>

[7] Wikipedia contributors, "Yahoo data breaches — August 2013: breach," Accessed: 2025-09-08.

[Online]. Available: https://en.wikipedia.org/wiki/Yahoo_data_breaches

Gegenhuber et al., "Hey there! You are using WhatsApp: Enumerating Three Billion Accounts for Security and Privacy," NDSS 2026.

Gegenhuber et al., "Hey there! You are using WhatsApp: Enumerating Three Billion Accounts for Security and Privacy," NDSS 2026

감사합니다.